GitHub 上 AI 渗透的 agent、工具、skills，我扒了一遍，开源地址全在这

实战笔记 · PENTEST × AI 安全

GitHub 上 AI 渗透的 agent、工具、skills，我扒了一遍，开源地址全在这

最近一年，AI 渗透测试这块从"没东西"变成"挤不进去"。朋友圈、群里隔三差五冒出个新 agent，号称一句话就能打穿。我花了半天，把 GitHub 上能搜到的 AI 渗透相关项目过了一遍，按"形态"分了类，把真正还在维护、星标过得去的挑出来，开源地址整理在文末。

先立住一句：工具是放大器，不是替身。会用的人拿它提速，不会用的人拿它给自己壮胆——后者在授权测试里都容易翻车，更别说别的场景。

> 下面所有项目，官方都标注了"仅限授权安全测试"。这句话不是客套，是底线。本文只做技术盘点，不提供任何利用方法。

01 先泼盆冷水：九成是"套壳"，真能打的就那一小撮

GitHub 上一搜 "AI pentest agent"，能翻出几十个仓库。点进去一半是这样：一个 ReAct 循环，套个 LLM，调几个 nmap、sqlmap，README 写得惊天动地，星标两位数，提交记录停在半年前。

真正值得看的，得同时满足三条：还在持续更新、架构不是糊弄、定位清晰（要么做深一个环节，要么做成能自部署的平台）。按这个标准筛，剩下的项目可以按"形态"分成三类。

02 三类形态：框架、编排、Skills

第一类，自主渗透框架。自己带 Agent 调度、记忆、工具链，你说目标它跑流程。代表是 PentAGI、PentestGPT、Strix、PentestAgent、CAI、ARTEX。这类最像"操作系统"，

重，但完整。

第二类，工具编排 / MCP 平台。不自己造 agent，而是把 nmap、nuclei、sqlmap、metasploit 这些老牌工具用 MCP 接给大模型指挥。代表是 HexStrike AI、DarkMoon、MCP Security Hub、RedTeam-Agent。这类轻，落地快，适合接进你现有的工作流。

第三类，Agent Skills。不是独立软件，是一堆写给 Claude Code / Cursor 的"技能文件"，让编码助手化身渗透副驾。代表是 0xSteph/pentest-ai-agents。这类最轻，装完就能用，适合个人。还有两个 awesome 清单专门做汇总，懒得一个个翻的可以直接看清单。

03 我愿意点开的几个（带实时星标）

项目	语言/星标	一句话定位
PentAGIvxcontrol/pentagi	Go 约 25.3k	最完整的自主渗透"操作系统"，自然语言派六路专家 agent 在 Docker 沙箱里干活，自动出报告。MIT。
PentestGPT GreyDGL/PentestGPT	Python 约 15.8k	开山之作，人机协同 copilot，你掌舵它给思路。学 AI 渗透从它读起最合适。MIT。
Strix usestrix/strix	Python 约 66.8k	自主 Web 应用测试 agent，跑真实代码、出带 PoC 的报告，Apache-2.0，维护活跃。
HexStrike AI 0x4m4/hexstrike-ai	Python 约 12.5k	MCP 指挥 150+ 安全工具，12+ 专精 agent（赏金/CTF/CVE 情报/利用生成）。MIT。
PentestAgent GH05TCREW/pentestagent	Python 约 3.2k	多智能体 + RAG + MCP，支持单 agent / crew / interact 多模式，自带 Kali 镜像。MIT。

pentest-ai-agents 0xSteph/pentest-ai-agents	Shell 约 2.3k	28+ 个专精子代理（侦察/Web/AD/云/报告…），装进 Claude Code 即用的 Skills 包。MIT。

星标为 GitHub API 实时值（2026-10-06），会随时间变动，以仓库页面为准。完整 15 个项目地址见文末汇总。

04 老兵的判断：它们帮得了你什么，帮不了什么

帮得了的：信息收集、资产梳理、指纹识别、报告生成——这些重复体力活，AI 比人快十倍，而且不喊累。还有"思路提示"，卡住时让它列几种可能的攻击面，常常能点醒你。

帮不了的：前两篇我写过，AI 给的 payload 十个九个跑不通，幻觉照样存在。更关键的是，它分不清"看起来像漏洞"和"真的是漏洞"。一个没验证的"疑似 SQLi"，在它嘴里能说得跟真事一样。所以结论还是那句——验真假的手，得是你自己的。

> 这些 agent 跑的是真刀真枪的攻击工具。在授权靶场里它是效率杠杆；出了授权边界，它就是违法工具。别拿"是 AI 自己干的"当借口——键盘是你敲的，目标你选的，责任跑不掉。

05 怎么用才不踩线

一，只在你有权限的目标上跑——自有系统、书面授权的靶场、客户给的范围。二，敏感数据别往外送：很多框架支持本地模型（Ollama）或私有 API， regulated 场景优先走本地，别把内网拓扑喂给公有云模型。三，开 human-in-the-loop，让它在每步执行前等你确认，别一键全自动。四，留好日志，出了事能复盘。

把这四点当铁律，AI 渗透就是趁手的好兵器；丢了任何一条，它就可能变成你的麻烦。

06 开源地址汇总（15 个，按上文顺序）

自主渗透框架

https://github.com/vxcontrol/pentagi （PentAGI）

https://github.com/GreyDGL/PentestGPT （PentestGPT）

https://github.com/usestrix/strix （Strix）

https://github.com/GH05TCREW/pentestagent （PentestAgent）

https://github.com/aliasrobotics/cai （CAI）

https://github.com/Autumn-27/ARTEX （ARTEX）

https://github.com/sec-js/redamon （RedAmon，早期）

工具编排 / MCP 平台

https://github.com/0x4m4/hexstrike-ai （HexStrike AI）

https://github.com/ASCIT31/Dark-Moon （DarkMoon）

https://github.com/FuzzingLabs/mcp-security-hub （MCP Security Hub）

https://github.com/ktol1/RedTeam-MCP （RedTeam-Agent）

Agent Skills 与汇总清单

https://github.com/0xSteph/pentest-ai-agents （28+ 子代理 Skills）

https://github.com/insidetrust/awesome-ai-pentest （awesome 清单）

https://github.com/fdgnneig/Awesome-AI-Hacking-Agents （64+ agent 清单）

https://github.com/ipa-lab/hackingBuddyGPT （学术极简，约 50 行起步）

参考来源：上述 15 个 GitHub 仓库（数据截至 2026-10-06，星标以 GitHub 实时为准）；awesome-ai-pentest 清单收录的 Deng et al. (2025) 综述与 XBOW/PentestGPT-Benchmark 评测。本文为技术盘点，所有项目均仅限合法授权测试使用。